

Detecção de Acesso Inicial em Ambientes AD

Olá, meu nome é Cauã. Neste relatório, documento minhas investigações de segurança focadas na detecção de **Acesso Inicial** em ambientes Active Directory (AD).

Visão Geral do Cenário

Em um ambiente AD (*Active Directory*), todo serviço exposto à internet que realiza autenticação no domínio representa um potencial ponto de entrada para ameaças. O foco desta documentação é detalhar a detecção de ataques de acesso inicial direcionados a três dos serviços mais comuns:

- Aplicações web IIS
- Exchange OWA
- Gateways VPN

Embora cada um desses cenários utilize uma fonte de log de aplicação diferente, a investigação segue um princípio fundamental comum a todos eles: **o ataque se torna visível primeiro nos logs da própria aplicação**. Apenas em um segundo momento, o escopo completo da intrusão é revelado ao correlacionar essas informações iniciais com outras fontes, como Sysmon e logs de Segurança do Windows.

Objetivos da Investigação

- Analisar logs do IIS para detectar ataques direcionados a aplicações web e atividades de *web shells*.
- Correlacionar eventos de autenticação do Exchange/OWA com os logs de Segurança do Windows.
- Investigar ataques de credenciais em VPN utilizando logs de eventos do NPS.
- Investigar atividades pós-autenticação para determinar o real impacto de uma violação.
- Construir linhas do tempo de investigação através da correlação entre logs de aplicação e logs de Segurança do Windows.

Superfície de Ataque e Análise de Logs do IIS no Active Directory

Em um ambiente Active Directory (AD), serviços expostos à internet (como aplicações web, Exchange e gateways VPN) centralizam a autenticação. Isso transforma cada serviço em um ponto de entrada potencial para toda a rede. Ao contrário de um servidor independente, onde um ataque afeta apenas aquela máquina, no AD um comprometimento da aplicação web pode expor o domínio inteiro.

O Papel do IIS e o Fluxo de Autenticação

O Internet Information Services (IIS) é o servidor web da Microsoft, utilizado para hospedar aplicações como Exchange e SharePoint. Quando um usuário tenta fazer login no IIS, a plataforma valida as credenciais no AD. Esse processo deixa rastros em três pontos distintos:

- **Logs de Acesso do IIS:** Registram os dados da requisição HTTP.
- **Logs de Segurança do Windows (Servidor Web):** Registram o Evento 4624 (Conta conectada com sucesso) ou Evento 4625 (Falha ao conectar uma conta).
- **Controlador de Domínio (DC):** Registra o Evento 4776 (Validação de credenciais).

Fundamentos de Registro do IIS

Os logs do IIS ficam armazenados em `C:\inetpub\logs\LogFiles\W3SVC1`.

Nota Crítica sobre Fuso Horário: O IIS registra os carimbos de tempo em **UTC**, independentemente do horário local do servidor. Isso é fundamental ao correlacionar entradas do IIS com os eventos de segurança do Windows (que usam horário local).

Na investigação, os campos essenciais do log para identificar ameaças são:

- **c-ip:** Endereço IP de origem.
- **cs-uri-stem:** Caminho acessado. Indica interação com possíveis *web shells* ou painéis administrativos.
- **cs-uri-query:** String de consulta. Pode conter comandos passados para *web shells*.
- **cs-method:** Método HTTP (GET/POST). Requisições POST para caminhos incomuns são altamente suspeitas.
- **sc-status:** Código de status HTTP (200 para sucesso, 401 para falha de autenticação, 302 para redirecionamento).
- **cs(User-Agent):** Identificador do navegador/ferramenta. Pode revelar automação, embora seja facilmente falsificado pelo atacante.

Padrões de Tráfego: Normal vs. Suspeito

O primeiro passo da análise é buscar anomalias. A tabela abaixo resume as diferenças entre um tráfego legítimo e um comportamento malicioso:

Indicador	Tráfego Normal	Padrão Suspeito
Volume	Poucos logins por usuário ao longo do dia.	Centenas de tentativas de login do mesmo IP em minutos.

Horário	Horário comercial, IPs e sub-redes conhecidas.	Madrugada, IPs ou sub-redes desconhecidas.
Caminhos URI	/owa/, /ecp/, /internalapp/default.aspx	/aspnet_client/system_web/shell.aspx ou /uploads/cmd.aspx
Consultas	?ViewAction=ReadMessage&ItemID=AAM	Comandos diretos, ex: ?cmd=whoami ou ?exec=ipconfig
Métodos	GET para páginas e POST para formulários de login.	POST direcionado a diretórios de arquivos estáticos.
Status HTTP	Erros 404 ocasionais (erros de digitação).	Centenas de erros 404 do mesmo IP em minutos (varredura).

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a fundamentação teórica sobre a arquitetura de autenticação em aplicações web conectadas ao Active Directory e analisei a estrutura de logs do Internet Information Services (IIS).
- **Os principais conceitos aprendidos:** O fluxo de autenticação do IIS gerando eventos no Windows e no Controlador de Domínio; a identificação de campos-chave nos logs do IIS (como **c-ip**, **cs-uri-stem** e métodos HTTP); a conversão mandatória de carimbos de tempo em UTC; e o mapeamento de padrões normais versus suspeitos no tráfego web.
- **Por que eles são importantes:** Entender o funcionamento da camada de aplicação e seus **logs** é crucial porque esses serviços são os principais vetores de entrada em um ambiente de domínio. A habilidade de detectar anomalias iniciais nos registros do IIS — como varreduras de diretório ou interação com *web shells* — permite isolar a ameaça antes que o atacante atinja a infraestrutura interna do AD.

Detecção de Implantação de Web Shell

Em continuidade à análise de logs do IIS, esta etapa focou em investigar o que ocorre quando um invasor explora com sucesso uma aplicação web e implanta um *web shell*.

Um *web shell* é um script malicioso (geralmente com a extensão **.aspx** em ambientes IIS) que permite ao atacante executar comandos do sistema operacional diretamente através de requisições HTTP. Eles são furtivos: sobrevivem a reinicializações, comunicam-se utilizando portas web normais e não exigem ferramentas adicionais.

Casos reais demonstram o impacto dessa técnica. Em 2021, o grupo HAFNIUM encadeou vulnerabilidades do Exchange Server (ProxyLogon) para implantar *web shells* "China Chopper" no diretório `C:\inetpub\wwwroot\aspnet_client\`. Em 2023, a CISA relatou o uso de *shells* semelhantes explorando vulnerabilidades na interface Telerik.

O Padrão de Detecção Principal

A atividade de um *web shell* possui uma assinatura distinta na cadeia de processos do sistema. Durante a operação normal do IIS, o processo de trabalho `w3wp.exe` lida com as requisições HTTP e gera respostas sem iniciar outros processos.

No entanto, quando um atacante interage com um *web shell*, o `w3wp.exe` atua como processo pai e cria processos filhos (como `cmd.exe` ou `powershell.exe`) para executar os comandos. Como aplicações legítimas do IIS raramente precisam executar *shells* de comando, esse comportamento é um forte indicador de comprometimento e exige investigação imediata.

1 index=iis cs_uri_stem = /aspnet_client/system_web/shell.aspx

2 | table _time, c_ip, cs_method, cs_uri_query, sc_status

3 | sort _time

All time

6 events (before 8/28/26 8:16:15.000 PM) No Event Sampling

Job

Smart Mode

Events

Patterns

Statistics (6)

Visualization

Show: 20 Per Page

Format

Preview: On

_time	c_ip	cs_method	cs_uri_query	sc_status
2026-02-12 10:44:15	203.0.113.47	GET	cmd=whoami	200
2026-02-12 10:44:15	203.0.113.47	GET	cmd=ipconfig	200
2026-02-12 10:44:15	203.0.113.47	GET	cmd=net%20user	200
2026-02-12 10:44:15	203.0.113.47	GET	cmd=net%20localgroup%20administrators	200
2026-02-12 10:44:15	203.0.113.47	GET	cmd=dir%20C:\Users	200
2026-02-12 10:44:15	203.0.113.47	GET	cmd=systeminfo	200

Metodologia de Investigação no Splunk

Para rastrear o ataque passo a passo, utilizei a seguinte metodologia correlacionando os logs do IIS com eventos de endpoint:

- Passo 1: Identificar a atividade de varredura (Scanning)** Antes de implantar o artefato, os atacantes costumam procurar caminhos com permissão de gravação. Busquei por uma sequência anormal de respostas `404` originadas de um único endereço IP (`index=iis sc_status=404 | stats count by c_ip`), o que indica claramente o uso de um *scanner* de diretórios.
- Passo 2: Encontrar o arquivo .aspx suspeito** Utilizando o IP suspeito identificado no Passo 1, filtrei as solicitações bem-sucedidas (`sc_status=200`) para ver quais recursos foram acessados. O foco principal foi o campo `cs_uri_stem`, prestando

atenção especial a diretórios como `/aspnet_client/`, que possui permissão de escrita nativa para o `w3wp.exe` e nunca deveria conter códigos de aplicação.

- **Passo 3: Rastrear Comandos e a Cadeia de Processos**

- **Via IIS:** Filtrei pelo nome do arquivo suspeito para analisar o campo `cs_uri_query`, revelando os comandos de reconhecimento passados via URL.
- **Via Sysmon:** Para confirmar a execução no disco, busquei eventos de criação de processos (EventCode 1 do Sysmon ou Evento 4688 do Windows) onde o `ParentImage` fosse o `w3wp.exe`. O cruzamento desses logs confirmou a execução dos mesmos comandos visíveis no tráfego web.
- **Passo 4: Descobrir o Momento da Implantação** Para estabelecer a linha do tempo, busquei o momento exato em que o arquivo foi gravado no disco utilizando o EventCode 11 (FileCreate) do Sysmon. Como alternativa, procurei requisições `POST` no IIS que contivessem o nome do `web shell`.

New Search

Save As Create Table View Close

1 index=win

EventCode=11

TargetFilename="*shell.aspx"

All time

2 | table _time, Image, TargetFilename

✓ 1 event (before 8/28/26 8:24:59.000 PM) No Event Sampling

Job

Smart Mode

Events Patterns **Statistics (1)** Visualization

Show: 20 Per Page

Format

Preview: On

_time	Image	TargetFilename
2026-02-12 10:43:18	c:\windows\system32\inetsrv\w3wp.exe	C:\inetpub\wwwroot\aspnet_client\system_web\shell.aspx

Evidências Extraídas (Questões Essenciais)

- **Pergunta:** Qual o nome do arquivo do *web shell* usado pelo atacante?
 - **Resposta:** `shell.aspx`
- **Pergunta:** Qual endereço IP foi usado para interagir com o *web shell*?
 - **Resposta:** `203.0.113.47`
 - **Explicação:** Identificado inicialmente pelo alto volume de erros 404 (varredura) e confirmado pelas requisições de sucesso (200) direcionadas ao arquivo malicioso.
- **Pergunta:** Após acessar o *web shell*, qual foi o primeiro comando de reconhecimento executado pelo atacante?
 - **Resposta:** `whoami`
 - **Explicação:** Extraído cruzando a string de consulta (`cs_uri_query`) no log do IIS com os argumentos de linha de comando no EventCode 1 do Sysmon.

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi a investigação de um ataque em aplicação web focando na detecção da implantação e utilização de um *web shell*.

Rastreiei a atividade desde a varredura inicial de diretórios até a execução de comandos no sistema operacional, utilizando buscas estruturadas no Splunk.

- **Os principais conceitos aprendidos:** O funcionamento e impacto de *web shells* (arquivos `.aspx`), a identificação de cadeias de processos anômalas (onde `w3wp.exe` gera processos de comando como `cmd.exe`) e as técnicas de correlação temporal e de IP entre logs web e eventos de sistema.
- **Por que eles são importantes:** Detectar *web shells* rapidamente é vital para impedir que o atacante mantenha persistência e execute comandos remotamente em servidores críticos. A capacidade de correlacionar **logs** de aplicação (IIS) com **logs** de endpoint (Sysmon) em um **SIEM** (como o Splunk) é o que permite visualizar não apenas a tentativa de acesso pela rede, mas o dano real e a execução no nível do sistema operacional.

Acesso Inicial: Exchange, OWA e Ataques de Credenciais

Embora a implantação de *web shells* seja uma tática comum contra aplicações hospedadas no IIS, a abordagem de acesso inicial mais frequente ocorre por meio de ataques de credenciais direcionados a páginas de login. Nesse contexto, o Exchange OWA (Outlook Web Access) é um dos alvos mais visados em ambientes corporativos, pois atua como a porta de entrada para o e-mail da empresa e é, por definição, acessível pela internet.

Como o Exchange é executado no IIS, o mesmo padrão de detecção envolvendo o processo `w3wp.exe` identifica explorações do sistema. No entanto, o foco desta etapa foi voltado especificamente para os ataques de credenciais, devido à sua alta incidência.

Terminologia do Ambiente

Para garantir a clareza da investigação, estruturei a análise com base na seguinte terminologia:

- **Exchange:** O servidor responsável por gerenciar o envio de e-mails, calendários e contatos.
- **Outlook:** O aplicativo cliente utilizado no desktop.
- **OWA (Outlook Web Access):** A versão baseada em navegador, hospedada no servidor IIS.

Comportamento do OWA nos Logs

Durante a análise do tráfego, observei como o OWA registra as tentativas de acesso:

- **Login Bem-sucedido:** Gera uma requisição `POST` com código HTTP `302` para `/owa/auth.owa`, redirecionando o usuário para a caixa de entrada. Em seguida, gera requisições `GET` conforme a interface é carregada.
- **Login com Falha:** Também retorna o código HTTP `302`, mas, em vez de acessar a caixa de entrada, redireciona o usuário de volta para a página de login.

Como ambos os resultados geram redirecionamentos `302`, o código de status HTTP do IIS não é suficiente para determinar se um login foi bem-sucedido ou não. O principal indicador

de uma falha de autenticação no OWA é a presença do parâmetro **reason=2** na *string* de consulta (query string). Além disso, o parâmetro **url** indica qual página o usuário tentava acessar inicialmente.

Para identificar quem está sofrendo o ataque, a investigação recorre aos logs de segurança do Windows. Na maioria das vezes, quando preciso do nome de usuário durante uma análise do OWA, busco os Eventos de Segurança **4624** (login bem-sucedido) e **4625** (login com falha), pois eles sempre registram o nome da conta alvo.

IIS Logs vs Windows Security Logs

_time	cs_method	cs_uri_stem	cs_uri_query	sc_status
2026-02-13 20:06:01	GET	/owa/		200
2026-02-13 20:06:01	POST	/owa/auth.owa		302

_time	EventCode	user	Process_Name	Logon_Type
2026-02-13 20:06:01	4624	michelle.smith	C:\Windows\System32\inetssrv\w3wp.exe	8

Diretórios Virtuais Críticos do Exchange

Para monitorar ameaças no Exchange e restringir a análise, concentrei minha atenção em dois caminhos principais:

- **/owa**: A página de login do Outlook Web Access. Este é o ponto exato onde ocorrem os ataques de credenciais.
- **/ecp**: O Painel de Controle do Exchange (interface administrativa). O acesso a este caminho deve ser raro e rigorosamente monitorado, pois, a partir dele, um invasor pode criar regras de encaminhamento, exportar caixas de correio ou modificar as configurações vitais do Exchange.

O que foi realizado

- **O que foi feito durante a atividade**: Realizei a fundamentação técnica sobre ataques de credenciais direcionados ao Exchange OWA, mapeando o comportamento de autenticação nos logs do IIS e estruturando a necessidade de correlação com eventos de segurança do sistema operacional.
- **Os principais conceitos aprendidos**: O comportamento dos redirecionamentos HTTP **302** no OWA, a utilização da *string* **reason=2** para identificar falhas de login, e a importância de correlacionar esses eventos web com os logs de Segurança do Windows (Eventos 4624 e 4625) para capturar os nomes das contas. Além disso, mapeei a criticidade dos diretórios virtuais **/owa** e **/ecp**.
- **Por que eles são importantes**: O monitoramento preciso dos **logs** do OWA é fundamental porque ataques de credenciais são os vetores mais comuns de acesso inicial a um domínio. Compreender que o IIS não expõe facilmente o nome de usuário em requisições de falha e que é necessário consultar o Evento 4625 do Windows garante a visualização completa do ataque. Monitorar o acesso ao **/ecp** é

igualmente crucial para impedir que um invasor assuma o controle administrativo de todo o fluxo de e-mails corporativos após comprometer uma credencial

Detecção de Ataques de Força Bruta no OWA

A implantação de um ataque direcionado ao Exchange OWA (Outlook Web Access) muitas vezes se inicia com a tentativa de adivinhar senhas. Como contexto prático, em janeiro de 2024, a Microsoft revelou que o grupo Midnight Blizzard (os mesmos responsáveis pelo ataque à SolarWinds) utilizou ataques de força bruta contra o ambiente corporativo Exchange da empresa. Eles comprometeram uma conta de teste legada sem autenticação multifator (MFA) e utilizaram esse acesso para ler e-mails da alta direção.

Cada tentativa de login no OWA gera um alerta **POST** no caminho `/owa/auth.owa`. Uma sequência rápida dessas requisições provenientes de um único endereço IP é um forte indicador de ataque de força bruta. Simultaneamente, falhas de login geram o Evento 4625 nos logs de segurança do Windows, enquanto o sucesso gera o Evento 4624.

Metodologia de Investigação no Splunk

Para investigar o ataque e correlacionar os eventos, utilizei a seguinte estrutura de análise passo a passo:

- **Passo 1: Identificar falhas de autenticação no OWA (IIS)** Busquei por requisições **POST** em `/owa/auth.owa` agrupadas em intervalos curtos de tempo (ex: 5 minutos). No nível dos logs do IIS, um ataque de força bruta parece idêntico a um ataque de pulverização de senhas (*password spraying*), pois o log web não registra qual conta foi o alvo (o campo `cs_username` geralmente fica vazio).
- **Passo 2: Identificar a conta alvo (Windows Security)** Para descobrir quem estava sendo atacado, recorri aos logs de segurança do Windows (Evento 4625). A conta com o maior número de falhas indicava o alvo primário. Foi fundamental observar o `Logon_Type=8` (NetworkCleartext), que é o indicador de como aplicativos hospedados no IIS se autenticam no Active Directory.
- **Passo 3: Correlacionar logins com os registros de segurança do Windows** Com o usuário alvo identificado, cruzei os dados buscando pelos Eventos 4624 e 4625. Isso revelou um agrupamento de entradas 4625 seguido imediatamente por uma entrada 4624 (o momento em que o atacante obteve sucesso).
Nota Técnica: Os logs do Windows (Eventos 4624/4625) muitas vezes mostram o campo de rede vazio ou com um IP local, pois o logon é processado localmente pelo IIS. O IP real do atacante só está presente nos logs do IIS, o que torna obrigatória a correlação de ambas as fontes.


```
index=win EventCode IN (4624, 4625) user="sarah.kim" Logon_Type=8
| table _time, EventCode, user, Process_Name, Logon_Type
| sort _time
```

_time ↕	EventCode ↕ ✓	user ↕ ✓	Process_Name ↕ ✓	Logon_Type ↕ ✓
2026-02-12 10:29:32	4624	sarah.kim	C:\Windows\System32\inetsrv\w3wp.exe	8
2026-02-12 10:40:15	4625	sarah.kim		8
2026-02-12 10:40:20	4625	sarah.kim		8
2026-02-12 10:40:27	4625	sarah.kim		8
2026-02-12 10:40:32	4625	sarah.kim		8
2026-02-12 10:40:37	4625	sarah.kim		8
2026-02-12 10:40:42	4625	sarah.kim		8
2026-02-12 10:40:48	4625	sarah.kim		8
2026-02-12 10:40:53	4625	sarah.kim		8
2026-02-12 10:40:58	4625	sarah.kim		8
2026-02-12 10:41:03	4625	sarah.kim		8
2026-02-12 10:41:10	4625	sarah.kim		8
2026-02-12 10:41:15	4625	sarah.kim		8
2026-02-12 10:41:20	4625	sarah.kim		8
2026-02-12 10:41:25	4625	sarah.kim		8
2026-02-12 10:41:30	4625	sarah.kim		8
2026-02-12 10:41:44	4624	sarah.kim	C:\Windows\System32\inetsrv\w3wp.exe	8

- Passo 4: Verificar atividade pós-autenticação** Detectar o comprometimento inicial é apenas metade da investigação. Em seguida, filtrei os logs do IIS utilizando o IP do atacante para verificar quais diretórios ele acessou após o login. O acesso a caminhos sensíveis como `/ecp` (painel de administração do Exchange) ou `/powershell` (Exchange Remoto PowerShell) evidencia que o invasor estava escalando seus privilégios para além da leitura de e-mails.

```
1 index=iis c_ip="203.0.113.47"
2 | stats count by cs_uri_stem
3 | sort - count
```

✓ 163 events (before 8/28/26 8:56:40.000 PM)

Events Patterns **Statistics (120)** Visu

Show: 20 Per Page ▼  Format ▼ 

cs_uri_stem ⇅

- /dev
- /docs
- /download
- /downloads
- /e4b11af6-dcb5-47a6-a26e-f5763ef741c8
- /ecp/**
- /editor
- /error
- /files
- /fonts
- /forum
- /ftp

Evidências Extraídas (Questões Essenciais)

- **Pergunta:** Quantas tentativas de login falharam durante o ataque de força bruta ao OWA?
 - **Resposta:** 15
- **Pergunta:** Qual nome de usuário foi comprometido com sucesso neste ataque?
 - **Resposta:** sarah.kim
 - **Explicação:** Identificado listando o volume de Eventos 4625 com Logon_Type=8 e confirmando a intrusão com o Evento 4624.
- **Pergunta:** Após o login bem-sucedido, qual caminho o invasor utilizou para acessar o console de administração do Exchange?
 - **Resposta:** /ecp
 - **Explicação:** Detectado na análise pós-autenticação nos logs do IIS filtrados pelo IP do atacante.

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi uma investigação completa de um ataque de força bruta contra o serviço Exchange OWA, correlacionando requisições web com eventos de sistema operacional para identificar o alvo, confirmar a quebra da credencial e rastrear o escalonamento de privilégios.
- **Os principais conceitos aprendidos:** O uso do **Logon_Type 8** para identificar fluxos de autenticação do IIS para o Active Directory; a distinção entre ataques de força bruta e pulverização de senhas; e as limitações isoladas de cada fonte (o IIS possui o IP real, enquanto o Windows retém a conta alvo).
- **Por que eles são importantes:** O domínio na correlação em um **SIEM** (Splunk) unindo **logs** do IIS e do Windows é estritamente necessário para uma resposta a incidentes eficiente. Sem a união dessas duas fontes, faltariam as informações de autoria (IP) ou impacto (conta comprometida). Rastrear a atividade pós-autenticação é vital para descobrir se o atacante assumiu o controle administrativo do ambiente (ex: via **/ecp**).

Acesso Inicial: VPN e Active Directory

A detecção de ataques contra aplicativos da web e o Exchange costuma focar nos registros do IIS. No entanto, a investigação de redes privadas virtuais (VPN) possui uma dinâmica diferente.

Gateways VPN geralmente são dispositivos de terceiros (como Fortinet, Cisco, Palo Alto, Ivanti), o que transfere a detecção dos logs do servidor web para os logs de autenticação. O princípio, contudo, permanece o mesmo: a VPN se autentica em um servidor web, o que significa que comprometer uma conta VPN resulta no comprometimento de uma conta do Active Directory (AD).

Fluxo de Autenticação VPN

Na maioria dos ambientes corporativos, o gateway VPN não se comunica diretamente com o Active Directory. Ele utiliza o protocolo RADIUS como intermediário. No ecossistema Windows, esse servidor RADIUS é chamado de **NPS (Servidor de Políticas de Rede)**.

Os eventos do NPS aparecem apenas quando o gateway VPN está configurado para usar RADIUS. Caso o ambiente configure os gateways para autenticar diretamente no AD via LDAP, não haverá geração de eventos NPS. Nesse cenário alternativo, a detecção passa a se basear nos eventos 4624/4625 no próprio gateway VPN e no Evento 4776 no Controlador de Domínio (DC) para a validação das credenciais.

IDs de Eventos do NPS

Quando a autenticação flui pelo RADIUS (NPS), os seguintes IDs de eventos são fundamentais para a investigação de segurança:

ID do Evento	Significado	Relevância para a Segurança

6272	Acesso concedido ao Servidor de Políticas de Rede.	Autenticação VPN bem-sucedida.
6273	O servidor de políticas de rede negou acesso.	Falha na autenticação VPN.
6274	O Servidor de Políticas de Rede descartou a solicitação.	Solicitação malformada ou rejeitada.

O Evento **6273** inclui um campo chamado **Reason Code** (Código de Motivo), que detalha a causa da falha:

- **Código 16 (Nome de usuário desconhecido ou senha incorreta):** Forte indicador de ataque de credenciais.
- **Código 48 (Nenhuma política de rede correspondente):** Conta não autorizada para VPN (erro de permissão/configuração, não de ataque).
- **Código 65 (Incompatibilidade na chave secreta):** Erro de configuração entre o RADIUS e o cliente.

Diferenciar o código 16 dos demais evita que falhas legítimas de configuração gerem alarmes falsos de segurança.

Atividade VPN: Normal vs. Maliciosa

O uso legítimo de VPN segue padrões previsíveis: usuários se autenticando em horário comercial, a partir de locais esperados e acessando recursos habituais. Falhas ocasionais (como erros de digitação de senhas) são normais e aparecem como Eventos 6273 isolados.

O cenário torna-se malicioso quando ocorrem falhas agrupadas. Dezenas de Eventos 6273 em rápida sucessão direcionados a um mesmo usuário indicam tentativas de força bruta ou pulverização de senhas. Grupos de ransomware, como o Akira, utilizam ativamente essa abordagem para obter acesso inicial, podendo exfiltrar dados em poucas horas após comprometer a VPN.

Por outro lado, ataques não se limitam à força bruta. Atacantes frequentemente compram credenciais vazadas de intermediários ou exploram vulnerabilidades no próprio produto VPN. Quando o invasor já possui a senha correta, a intrusão gera um único Evento **6272** (acesso concedido), sem falhas prévias, parecendo um login idêntico ao legítimo. Nesses casos, a detecção de ameaças passa a depender inteiramente da análise do comportamento **pós-autenticação**: investigar a quais hosts o usuário se conecta e se a atividade desvia de seu padrão histórico.

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a estruturação teórica sobre fluxos de autenticação VPN baseados em RADIUS/NPS em ambientes integrados ao Active Directory. Analisei os IDs de eventos de segurança gerados e mapeei os códigos de erro associados.
- **Os principais conceitos aprendidos:** O fluxo de intermediação de autenticação via NPS (Network Policy Server), a interpretação dos Eventos NPS 6272 (sucesso), 6273 (falha) e 6274 (descarte), bem como o uso do **Reason Code** (especialmente o código 16) para distinguir ataques de força bruta de meras falhas de configuração.
- **Por que eles são importantes:** Entender o padrão de **logs** da VPN é fundamental para proteger a borda da rede. A capacidade de identificar padrões de ataque — como os utilizados por grupos de ransomware — ou reconhecer quando logins com sucesso exigem análise de comportamento pós-autenticação permite interceptar o acesso inicial antes que o domínio sofra exfiltração de dados.

Deteção de Ataques a Credenciais de VPN

Este foi o terceiro e último cenário de investigação. Apliquei a mesma metodologia das análises anteriores, mas com uma mudança crucial na fonte dos **logs**: utilizei os registros do NPS (Network Policy Server) em vez do servidor web (IIS).

Metodologia de Investigação no Splunk

Para rastrear o ataque de credenciais direcionado à VPN, segui um processo estruturado em três etapas:

- **Etapla 1: Identificar o escopo do ataque** Iniciei a análise filtrando os eventos de recusa de acesso do NPS (Evento 6273). Essa filtragem me permitiu visualizar quais nomes de usuário estavam sendo alvos e de quais endereços IP de clientes RADIUS as requisições se originavam. É importante ressaltar que o campo **Client_IP_Address** identifica o gateway VPN que encaminhou a solicitação, e não o IP real do atacante que tentou se autenticar.
- **Etapla 2: Encontrar a conta comprometida** Para verificar se o invasor obteve sucesso em alguma das tentativas, filtrei os eventos da conta alvo buscando tanto recusas (6273) quanto aceitações (6272). A visualização desse padrão suspeito (múltiplas recusas seguidas de um sucesso) é um forte indicativo de um ataque de força bruta.
- **Etapla 3: Correlacionar com eventos de logon de segurança** Em seguida, correlacionei o resultado da autenticação do NPS com os **logs** de segurança do Windows (Eventos 4624 e 4625). Quando o NPS valida as credenciais, ele autentica o usuário no Active Directory. Como no ambiente deste laboratório o NPS é executado no próprio Controlador de Domínio (**THM-DC**), ele cria uma sessão de logon local. Isso gerou um agrupamento de entradas 4625 (falhas) seguido por uma 4624 (sucesso), com o registro de data e hora correspondendo aproximadamente ao evento 6272 da etapa anterior.
Nota sobre o ambiente de produção: Em um ambiente corporativo real, onde o NPS é executado em um servidor separado, os eventos 4624/4625 apareceriam no

servidor NPS. O Controlador de Domínio (DC) registraria apenas o Evento 4776 (Validação de Credenciais) para cada tentativa, pois ele apenas valida a senha sem criar uma sessão local.

A extração desses eventos de segurança é fundamental, pois eles incluem o **LogonId**, um identificador que permite rastrear a atividade da sessão do usuário logo após a autenticação.

Evidências Extraídas (Questões Essenciais)

- **Pergunta:** Qual nome de usuário foi comprometido com sucesso via VPN após o ataque de credenciais?
 - **Resposta:** david.chen
 - **Explicação:** Identificado ao rastrear a sequência de Eventos 6273 (falhas) culminando em um Evento 6272 (sucesso) associado à conta.
- **Pergunta:** Com base no evento de aceitação de acesso do NPS, a que horas ocorreu a autenticação VPN bem-sucedida?
 - **Resposta:** 10:47:06
 - **Explicação:** Obtido a partir do carimbo de data e hora (*timestamp*) exato do Evento 6272 gerado após a força bruta.

```
index=win EventCode IN (6273,6272) User_Account_Name=david.chen  
| table _time, EventCode, User_Account_Name, Client_IP_Address
```

2026-02-12 10:47:06

6272 david.chen

10.5.10.200

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi a investigação de um ataque de credenciais direcionado a um gateway VPN, utilizando o Splunk para analisar os **logs** do servidor RADIUS/NPS e correlacioná-los com eventos de login do Windows.
- **Os principais conceitos aprendidos:** A interpretação prática dos **logs** do NPS (Eventos 6272 e 6273) e sua integração com os eventos do Active Directory (4624, 4625 e 4776). Compreendi as limitações do campo de IP do cliente (que mostra o gateway, não o atacante) e as diferenças arquitetônicas entre servidores NPS isolados e integrados ao Controlador de Domínio.
- **Por que eles são importantes:** Analisar a autenticação baseada em RADIUS é essencial para proteger perímetros de rede. A capacidade de correlacionar os **logs** do NPS com o Active Directory comprova a eficácia de um ataque de força bruta e fornece o **LogonId**. Esse identificador é a chave para dar continuidade à investigação, permitindo monitorar com exatidão qualquer atividade pós-comprometimento executada sob a sessão do invasor.

Cenário de Investigação Final: Atividade HTTP Suspeita (Alerta do SOC)

Nesta etapa final, coloquei em prática toda a metodologia aprendida ao longo da atividade para resolver um incidente. O alerta inicial que desencadeou esta investigação pela equipe do SOC foi gerado devido a um volume incomum de respostas HTTP 404 em um dos servidores web IIS da organização, todas originadas de um único endereço IP externo. Minha tarefa foi atuar no ambiente de investigação para reconstruir a cadeia de eventos e descobrir exatamente o que aconteceu.

Metodologia de Investigação no Splunk

Utilizando os índices `index=iis` (para logs de acesso do IIS) e `index=win` (para eventos Sysmon e segurança do Windows), segui os rastros deixados pelo IP suspeito para entender a extensão do ataque:

- **Identificação do Artefato:** A partir do volume anômalo de erros 404, isolei o IP de origem e rastreei suas requisições subsequentes para identificar a implantação de um *web shell*.

```
1 index=iis c_ip=198.51.100.23 sc_status=200
2 | stats count by cs_uri_stem
3 | sort - count
```

✓ 9 events (before 8/28/26 9:34:20.000 PM) No Event Sampling ▾

Events Patterns **Statistics (4)** Visualization

Show: 20 Per Page ▾ ↗ Format ▾ ☒ Preview: On

cs_uri_stem ⇅

- /aspnet_client/system_web/error.aspx
- /internalapp/upload.aspx
- /internalapp/
- /internalapp/default.aspx

- **Análise de Interação:** Investiguei as requisições direcionadas ao arquivo malicioso para descobrir qual foi o primeiro comando de reconhecimento executado pelo atacante no servidor.
- **Vetor de Upload:** Analisei os logs de tráfego HTTP anteriores à execução para mapear o caminho URI exato utilizado para enviar o artefato.
- **Linha do Tempo:** Correlacionei os eventos do IIS com os eventos do sistema para determinar o horário exato da criação do *web shell*.

1

index=win EventCode=11 TargetFilename="*error.aspx"

2

| table _time, Image, TargetFilename

All time ▾

✓ 1 event (before 8/28/26 9:32:51.000 PM)

No Event Sampling ▾

Job ▾

Smart Mode ▾

Events

Patterns

Statistics (1)

Visualization

Show: 20 Per Page ▾

Format ▾

Preview: On

_time ▾	Image ▾	TargetFilename ▾
2026-02-17 10:40:33	c:\windows\system32\inetrv\w3wp.exe	C:\inetpub\wwwroot\aspnet_client\system_web\error.aspx

Evidências Extraídas (Questões Essenciais)

- **Pergunta:** Qual é o nome do arquivo do *web shell* que o atacante implantou?
 - **Resposta:** **error.aspx**
- **Pergunta:** Qual foi o primeiro comando de reconhecimento executado pelo atacante através do *web shell*?
 - **Resposta:** **hostname**
 - **Pergunta:** Qual foi o caminho URI usado para enviar o *web shell* para o servidor?
 - **Resposta:** **/internalapp/upload.aspx**
- **Pergunta:** A que horas o arquivo *web shell* foi criado no servidor?
 - **Resposta:** **10:40:33**

O que foi realizado

- **O que foi feito durante a atividade:** Apliquei de forma prática todo o conhecimento adquirido nas etapas anteriores para atuar como analista de **SOC** respondendo a um alerta de anomalia **HTTP**. Reconstruí a cadeia do ataque cruzando **logs** no **Splunk** (**index=iis** e **index=win**), o que me permitiu identificar o vetor de upload, o nome do arquivo malicioso, a hora exata da sua criação no disco e os comandos de reconhecimento.
- **Os principais conceitos aprendidos:** A consolidação e aplicação prática da investigação ativa baseada em alertas de varredura de diretórios, correlacionando logs de acesso web (IIS) com logs de segurança de *endpoint* para documentar o ciclo de vida completo de um *web shell*.
- **Por que eles são importantes:** O tratamento eficaz de um alerta do **SOC** exige a reconstrução precisa da linha do tempo. Colocar essa metodologia em prática demonstra a capacidade de identificar o caminho URI utilizado para o upload e os comandos executados, garantindo que a equipe possa fechar a vulnerabilidade inicial e verificar se o invasor escalou privilégios a partir do acesso inicial.